

CAIRN — Technical & Executive Brief

The knowledge-integrity layer for regulated firms

JourdanLabs Brief · Version 1.0 · July 2026 Leland Jourdan II, Founder & Chief Architect, JourdanLabs

· leland@jourdanlabs.com

SOFTWARE: WORKING · TESTS: 53/53 · DEPENDENCIES: 0 · RUNS: FULLY LOCAL · INDEPENDENTLY RE-VERIFIED

1. The one-sentence version

CAIRN surveils a firm's knowledge base for contradiction and staleness, and answers questions **only with what it can prove** — emitting a cryptographic receipt for every answer *and* every refusal.

2. Why this matters now

In a regulated firm the knowledge base is not documentation — it is a **control surface**. Policies, procedures, risk memos, and control narratives are how people, and increasingly AI assistants, know what to do. That surface rots in four predictable ways:

- **Inconsistent** — two procedures give conflicting instructions and nobody notices.
- **Stale** — the authoritative version was superseded, but the old one is still what search returns.
- **Ungrounded** — answers get sourced from the nearest-sounding document, not the correct one.
- **Un-auditable** — when a regulator asks "*how did your people know to do X,*" nothing ties the action to the source that informed it.

Firms are wiring AI assistants directly onto these knowledge bases right now. That does not shrink the problem; it **scales** it — the volume of confident, unsourced, un-auditable answers rises fastest precisely inside the environments least able to absorb the risk. In most industries this is a nuisance. In regulated finance it is a control failure. **The control needs to exist before the incident does.**

3. The category

CAIRN is not enterprise search and not a document chatbot. Those optimize for *finding* and *answering*.

CAIRN optimizes for **integrity and provenance**: whether the corpus agrees with itself, and whether every answer traces — cryptographically — back to the exact source that produced it. Search asks "*what's relevant?*"

CAIRN asks "*can we prove it, and does the knowledge base even agree with itself?*"

4. What it does — three pillars

4.1 Receipted, cite-or-refuse answers

Ask a question over the corpus; CAIRN returns an answer **locked to the retrieved notes**. Every claim carries a citation, or the system replies exactly *"Not in your vault."* A confidence gate refuses weak matches **before the model is ever called**, so the model is never asked to fill a gap it cannot ground. Every answer *and* every refusal emits a hashed **receipt** containing: the question; the verdict (`GROUNDED` / `REFUSED_UNGROUNDED`); each cited source **content-hashed with SHA-256** (proof of exactly what the source said at answer time); the model; the confidence; the index build time; a timestamp; and a `receipt_sha256` . It downloads as JSON.

Refusal is treated as a **first-class, receipted outcome** — "Not in your vault" is a feature, not a failure. A wrong-but-confident answer is the exact thing CAIRN is built to prevent.

4.2 Contradiction & staleness surveillance

A deterministic audit finds the structural rot — orphans, broken `[[links]]` , stale notes, duplicate titles, stubs, untagged notes — with reproducible penalties. Embedding-based **overlap detection** surfaces note pairs about the same topic, and a model adjudicates whether they **contradict**, **duplicate**, or merely **relate**. This is the part no search engine does: it does not just retrieve the corpus, it interrogates it for internal conflict. Surveillance can re-run and alert only on **new** defects since the last sealed baseline (webhook / file / SIEM sinks).

4.3 A hashed knowledge-integrity score

One click produces an **Integrity Report**: a 0–100 score and letter grade over the whole corpus, combining the deterministic audit with the contradiction candidates, rolled into a single hashed (`report_sha256`), downloadable JSON artifact — a regulator-ready snapshot of whether the knowledge base is internally consistent, current, and reachable.

Controlled sources. Authoritative documents are marked *controlled* (by folder or frontmatter). The report shows controlled coverage, and same-topic overlaps between two controlled documents are surfaced as **review priorities** — a genuine conflict between two authoritative policies is the costliest kind, so it is the first to adjudicate. Scoring is deliberately conservative: structural defects carry deterministic penalties; a contradiction is penalized heavily **only once adjudication confirms it**, not on similarity alone.

5. How it is built

```
sources → CONNECTORS → INGESTION → STORES → ENGINES → API → clients
(filesystem, (normalized (parse → (docs, (hybrid (REST,
Confluence, Document chunk → vectors, retrieval, RBAC,
REST) model) index) receipt grounded audit)
ledger, answer,
reports) audit,
surveillance)
```

- **Zero runtime dependencies.** Pure Node.js (≥ 18), built-ins only — no npm packages to install, patch, or supply-chain-attack. `git clone` → `node server.mjs` and it runs; nothing to build.
- **Local by default.** The corpus is indexed in memory; nothing leaves the machine unless an external model endpoint is configured. Embeddings and chat can run fully local via Ollama. Grounded search needs no network at all.
- **Hash-chained receipt ledger.** Every answer and report is sealed into an append-only log where each entry binds the prior entry's hash — tamper-evident by construction. A verify endpoint recomputes the whole chain.
- **Connectors.** A normalized `Document` model lets any source ingest identically. The filesystem connector is live; a Confluence Cloud connector is coded against the real v2 REST API and fixture-tested. A live pull needs the customer's tenant + token.
- **Scale.** Contradiction candidate-generation uses an in-process approximate-nearest-neighbor (LSH) index instead of an $O(n^2)$ scan — no external vector database — with an exact-parity test guaranteeing it recovers the same candidates the brute-force scan would.
- **Access control.** Role-based (viewer / analyst / admin), API keys, and an OIDC-ready `verifyBearer` hook to wire a firm's SSO with no code change. Deny-by-default; open (single-user local) mode until keys are configured. Binds loopback by default.
- **Compliance pack.** A control-mapping document (cited to code, no false certification claims) and an auditor evidence export bundling the current integrity posture + the full sealed receipt chain + its verification.

6. Competitive landscape (honestly)

- **Enterprise search (Glean and peers)** finds documents well. It does not verify them, does not score the corpus for internal conflict, and does not receipt its answers.
- **Document AI (Notion AI, Copilot)** answers fluently and cloud-side. Fluency is not provenance; a good answer from the wrong document is still wrong, and there is no artifact proving where it came from.
- **RAG plugins** ground answers in retrieved chunks but stop there — no cite-or-refuse discipline, no corpus-level integrity score, no hashed receipt.

Nobody in the field scores the corpus for internal contradiction, and nobody hands you a signed receipt for the answer. That is the open lane.

7. What it is — and is not

CAIRN is a **control you operate**, not a certification. It produces the evidence a SOC 2 / model-risk / data-residency review asks for; certification is a property of *your* operated system, not of a component. It is **not** a chatbot (it refuses rather than improvises), **not** a search bar (retrieval is the input, provenance is the product), and **not** cloud RAG (it runs local; the corpus never leaves the machine).

Honest boundaries. The connectors, SSO hook, and deployment are config-driven and coded to real vendor APIs, but the last mile that physically lives in the customer's environment — a live Confluence/SharePoint

tenant token, the bank's identity provider, their VPC/on-prem deployment, and any certification — runs on their systems, not ours. Two capabilities are currently **scaffolded but not wired**: a per-request access log and an interval surveillance scheduler (surveillance runs on demand today). The receipt ledger assumes a single writer per file. None of this is smoothed over; it is stated so the buyer knows exactly what they are getting.

8. Status & proof

CAIRN is code-complete for what can be built and tested without a customer's environment: **53 automated tests passing, zero dependencies**, and independently re-executed rather than taken on trust — including a tamper-evidence stress test that edited a payload, broke a chain link, and deleted a line, all three caught with the correct reason. It ships with two faces: the **zero-dependency server + API** a firm deploys, and a local **desktop Studio** for an individual operator — same core, different audience.

9. Roadmap

Wire the access log and surveillance scheduler; live connector runs against a customer tenant; SSO against a real IdP; receipt-chain export tooling; and hardened multi-writer ledger semantics. Each ships with tests, and each honest boundary closes only when it is genuinely closed.

Built by JourdanLabs. We build tools that refuse to bluff.